NEXUS · DOCUMENTATION PACKAGE · DELIVERABLE 08

Engineering Audit

Evidence-based findings with severity, confidence, affected area and recommended action, plus an addendum verifying earlier remediation.

Document control

Document ID	NX-08-AUD
Version	1.0
Date	2026-11-05
Status	Draft for team review (not approved)
Intended readers	Development team prioritising fixes; assessor reviewing quality assurance
Evidence baseline	Branch New-Changes at commit 3a3f275 (tree identical to main at 9f8e82a)
Prepared by	AI-assisted (Claude Code) from repository evidence; team review pending
Approved by	Unknown No approval recorded

Evidence labels used in this document: Implemented verified in code, configuration or test output; Inferred reasoned from evidence but not executed; Recommendation proposed, not implemented; Open question needs a decision; Unknown no evidence available; Estimate planning figure, not a measurement.

Contents

1. 1 Scope and method
    1. 1.1 Ratings
2. 2 Summary
3. 3 Findings
4. 4 Addendum: verification of earlier remediation

1 Scope and method

This audit covers the repository at the evidence baseline: Android source, backend source, build and CI configuration, tests, and existing documentation. The methods were code reading, running both test suites, retrieving GitHub Actions run history, and one targeted reproduction (AUD-01) in a scratch directory.

> **Not a security audit.** No penetration test, threat model, dependency vulnerability scan (`npm audit` /OWASP) or formal security review was performed. Security-relevant observations below come from reading code and must not be read as a security assessment.

1.1 Ratings

- **High**: likely data loss, broken core function, or blocked release. **Medium**: real user or operational impact under plausible conditions. **Low**: limited impact or quality debt. **Info**: observation.
- Confidence: **Verified** (reproduced or shown in logs/tests), **High** (unambiguous in code/config), **Medium** (depends on environment or library behaviour not exercised here).

2 Summary

Findings by severity

Severity	Count	IDs
High	3	AUD-01, AUD-03, AUD-04
Medium	6	AUD-02, AUD-05, AUD-06, AUD-08, AUD-18, AUD-19
Low	10	AUD-07, AUD-09, AUD-10, AUD-11, AUD-12, AUD-13, AUD-14, AUD-16, AUD-17, AUD-21
Info	2	AUD-15, AUD-20

Strengths observed: transactional offline outbox with idempotent server receipts; consistent per-account data scoping on both tiers; strict startup secret check; atomic file writes; standard error shape; injected fakes that make ViewModels testable; honest scoping in the existing docs (the addendum explicitly forbids claiming unbuilt features).

3 Findings

Engineering findings

ID	Finding and evidence	Severity / confidence	Area	Recommended action
AUD-01	**Unreadable data file is silently replaced with an empty store.** `loadDatabase()` catches a JSON parse error, logs it, and continues with empty maps; the next write overwrites the file. Reproduced 2026-11-05: a truncated file loaded as 0 users and was rewritten as `{"users":[],...}` by the first `saveDatabase()`.	**High** / Verified	Backend persistence	Exit non-zero on a parse failure; keep a `.bak` before each rename. IMP-03

ID	Finding and evidence	Severity / confidence	Area	Recommended action
AUD-03	**Open Dependabot PR #27 (Zod 4) breaks all request validation.** `validate()` reads `result.error.errors`, which is undefined on Zod 4. CI run 2026-10-31 shows `TypeError … reading 'map'` at `server.js:133`, so invalid input would return 500 instead of 400. `z.record(z.unknown())` in `syncSchema` also uses the single-argument form that Zod 4 changed (not verified).	**High** (if merged) / Verified	Backend dependencies	Do not merge as-is; migrate to `error.issues` and `z.record(z.string(), z.unknown())`. IMP-02
AUD-04	**The current code has never passed CI.** Every workflow run for PRs #25 and #26 and their merges failed in 3–5 s with the annotation "job was not started because your account is locked due to a billing issue". The last green Android CI on main was 2026-09-24 (CI-RUN-GREEN).	**High** / Verified	Delivery	Resolve the account lock and re-run CI on main. IMP-01
AUD-02	**Root `docker-compose.yml` conflicts with the Docker image.** It sets `DATABASE_PATH=/usr/src/app/nexus-data.json` and bind-mounts a single host file there. The image runs as `node` with `WORKDIR /app`, so the server cannot create `nexus-data.json.tmp` in the root-owned `/usr/src/app`, and renaming over a bind-mounted file is not possible. If the host file does not exist, Docker creates a directory in its place. `backend/compose.yaml` (named volume at `/data`) is consistent.	**Medium** / Medium (not executed; Docker daemon unavailable)	Deployment config	Delete the root file or align it with `backend/compose.yaml`. IMP-05
AUD-05	**Cached user content is included in Android backups.** `allowBackup="true"`; the backup and extraction rules exclude only `sharedpref`, so `nexus_database` (projects, tasks, habits, pending queue) goes to cloud backup and device transfer.	**Medium** / High	Android privacy	Exclude the `database` domain, or document the decision. IMP-09
AUD-06	**Auth rate limiting will misbehave behind a TLS proxy.** `trust proxy` is not set, so `req.ip` is the proxy address and all users would share one 10-per-15-min bucket. Hosting requires a TLS proxy (OPS-01).	**Medium** / Medium	Backend security / ops	Configure `trust proxy` for the chosen host. IMP-06
AUD-08	**No release signing configuration.** `app/build.gradle.kts` defines no `signingConfig`, so CI release artifacts would be unsigned and could not be installed or published.	**Medium** / High	Release	Add signing from CI secrets. IMP-07

ID	Finding and evidence	Severity / confidence	Area	Recommended action
AUD-18	**Misleading sign-in and registration errors.** `toApiError()` maps every 401/403 to `SessionExpired`, so a wrong password shows "Your session has expired. Please log in again." A 409 (email taken) and a 429 (rate-limited) both show "Something went wrong. Please try again."	**Medium** / High	Android auth UX	Map auth-endpoint statuses separately. IMP-04
AUD-19	**One rejected operation blocks the whole upload queue.** Uploads stop at the first failure; a 400 or 409 needs the user to choose "Discard item edits". Until then no later change for any item uploads, though they stay saved locally.	**Medium** / High	Sync design	Keep the ordering guarantee per entity only, or surface the blocked item by name in Review. Document it in the user manual (done in NX-10-UM).
AUD-07	**Throughput is bounded by one global lock.** Every authenticated handler, including bcrypt cost-12 hashing and full-file rewrites, runs under `dbMutex`. Sync receipts (`syncOperations`) grow without limit, and dashboard refresh makes one request per project.	**Low** / High	Backend performance	Hash outside the lock; cap or expire receipts; add a bulk tasks endpoint. Revisit with the SQLite plan.
AUD-09	**Documentation drift.** README contents links to five sections that do not exist (Roadmap, Continuous Integration, Part 2 PoE Evidence, Security and Release Notes, Contributing). It claims "MyMemory translation fallback", but `OnlineLanguageRepository` has no callers. It labels a test user "Global system administrator" though no roles exist. It lists full multi-language support, which is partial. The project list header shows a stray "?" (encoding).	**Low** / High	Documentation	IMP-16
AUD-10	**"Task due-date reminders" switch has no effect.** No notification permission, channel, WorkManager or AlarmManager code exists; the switch only stores a preference.	**Low** / High	Android feature	Hide it, or implement reminders (OQ-01, IMP-08).
AUD-11	**CSV export is not escaped.** Rows are `"${name},${frequency},$date"`; commas, quotes or newlines in a habit name corrupt the file.	**Low** / High	Android export	IMP-13
AUD-12	**Room migrations are untested and incomplete.** `exportSchema = false`; there are no migrations for 1→2 or 2→3, and no destructive fallback, so a device with a v1/v2 database would fail to open it. There are no migration tests.	**Low** (no public release yet) / High	Android data	IMP-15

ID	Finding and evidence	Severity / confidence	Area	Recommended action
AUD-13	**Lint is configured but not enforced.** ktlint, detekt and Kover are in the build, but CI runs only `test` / `assemble`. The committed `build-verification.log` (UTF-16) records a failed local `ktlintFormat` ("KtLint failed to parse file … app/build.gradle.kts"). `blank.yml` is a starter template.	**Low** / High	Code quality / CI	IMP-10
AUD-14	**Test account passwords are committed.** `docs/seed_test_users.ps1` and the README contain plain-text passwords for three seed accounts. This is acceptable for local development, but the accounts must never be seeded on a hosted API.	**Low** / High	Security hygiene	Release checklist item REL-09; consider generating the passwords at seed time.
AUD-16	**Minor auth weaknesses.** Login returns before any bcrypt work for unknown emails, so timing could reveal registered emails. A legacy path accepts a stored non-bcrypt value as a plain-text password. Email uniqueness is case-sensitive.	**Low** / High	Backend auth	Compare against a dummy hash; remove the legacy path once no such records exist; normalise emails to lower case.
AUD-17	**Habit completion rate is understated with several habits.** `HabitScoring` counts distinct dates across all habits but sums the schedule per habit. Two daily habits both done for 30 days score 50%. Streaks also count a day if *any* habit was done.	**Low** / High	Domain logic	IMP-14
AUD-21	**UI screenshot set does not show the screens it names.** `docs/screenshots/ui-audit/` holds 9 files but only 4 distinct images (MD5): `dashboard-offline`, `profile`, `project-list` and `settings` are identical. `habits`, `project-list-skeleton`, `login` and `register` are also skeleton states, and `splash.png` shows the Login screen.	**Low** / Verified	Evidence / documentation	Recapture before submission; do not present these files as evidence of named screens. IMP-16
AUD-15	**Dead code.** `AuthSession.OFFLINE_TOKEN_PREFIX` handling remains after synthetic offline auth was removed; `setOnSessionCleared` is never registered; `OnlineLanguageRepository` and `languageInstance` are unused.	**Info** / High	Android	Remove during the next refactor.
AUD-20	**Inert or ordering quirks in the API.** `registrationEnabled` in `/app/config` is not enforced. Validation runs before authentication on several routes, so an unauthenticated request with a bad body gets 400 instead of 401. CORS is `*` (documented as intentional).	**Info** / High	Backend	Address when roles or a web client are introduced.

4 Addendum: verification of earlier remediation

`PROJECT_IMPROVEMENTS.md` records two remediation passes (2026-09-23 backend, 2026-09-24 Android). Each claim was checked against the baseline code and test evidence.

Remediation claims versus evidence

Claimed remediation	Code evidence	Test evidence (2026-11-05)	Result
AsyncMutex + atomic `.tmp` / `rename` writes	`AsyncMutex`, `withDb`, `saveDatabase()`	"Concurrent PATCH requests …" passed	Confirmed; see AUD-01 for the remaining load-path gap
Zod validation on all write endpoints	Schemas for register, login, profile, password, project, task, habit, sync	Validation tests passed (Zod 3)	Confirmed on Zod 3; at risk with Zod 4 (AUD-03)
JWT secret ≥ 32 chars, 24 h expiry, bcrypt 12, 10/15 min rate limit	`server.js` lines for each	Startup-refusal, expired-token and 429 tests passed	Confirmed; proxy caveat AUD-06
`/health` + Pino with redaction	Routes and `redact.paths`	Health test passed	Confirmed
Repository split, manual DI, `HabitScoring`, type-safe routes, shared fakes	`data/*Repository.kt`, `NexusApp`, `domain/`, `Route`, `test/fakes/`	32/32 unit tests passed	Confirmed
Synthetic offline authentication removed	No code mints offline tokens	Not separately tested	Confirmed, with leftover parsing code (AUD-15)